

Självstudier vecka 1

Projektstart och agil leverans i cybersäkerhetsprojekt

Syfte

Dessa skriftliga övningar hjälper dig att bygga vidare på Workshop 1. Du tränar på teamarbete, backlog, prioritering, Sprint Goal och Definition of Done inför nästa workshop om MITRE ATT&CK.

Så arbetar du med övningarna

- Svara individuellt eller i grupp enligt lärarens instruktion.
- Använd gärna era egna anteckningar från Workshop 1.
- Fokusera på tydliga resonemang, inte på perfekta formuleringar.
- Det ni skriver kan återanvändas i Team Charter, backlog, Sprint Goal och Definition of Done.
- Inför Workshop 2 ska gruppen vara redo att använda sitt arbetssätt för MITRE ATT&CK och hotanalys.

Översikt

Del	Fokus	Övningar
Del 1	Reflektion kring säkerhetsteam	1-3
Del 2	Teamarbete	4-6
Del 3	Product Backlog	7-10
Del 4	Prioritering	11-13
Del 5	Sprint Goal	14-16
Del 6	Definition of Done	17-18
Del 7	Förberedelse inför MITRE ATT&CK	19-20

Del 1 - Reflektion kring säkerhetsteam

Övning 1

Vad skiljer ett cybersäkerhetsteam från en vanlig utvecklingsgrupp?

Svarsinstruktion: Skriv 150-300 ord. Ge gärna exempel på ansvar, arbetsflöden och typer av leverabler.

En utvecklingsgrupp producerar funktionalitet och användarvänlighet. De ser till att en produkt gör vad det är tänkt att den ska göra. De ansvarar för att produkten inte är full med buggar och att kunderna får vad de vill ha. Ett cybersäkerhetsteam ser till att produkten inte gör sånt den inte borde göra, eller att någon som inte är kunden kan missbruka den. De ansvarar även för att lagar och regler följs och att standarder och ramverk efterlevs. Risker och hot som säkerhetsteamet upptäcker ska meddelas till utvecklarna, så att dessa kan hantera och eliminera risken eller hotet. Utvecklare har, enligt mig, lättare att jobba i sprintar. De har en funktion som ett mål och vet oftast hur de ska göra för att funktionen ska implementeras. Det behöver finnas en kommunikation mellan utvecklarna och säkerhetsteamet så att utvecklarna vet vilka risker som finns och behöver lösas. Säkerhetsteam måste förstå hotbilden och se risker. Mycket går att göra agilt, men man måste vara försiktig så att man inte eliminerar en risk i en sprint och skapar en ny som ingen har koll på förrän sprinten efter. Utvecklare levererar (förhoppningsvis) en färdig funktion efter en sprint. Säkerhetsteamet levererar en mindre hotbild och hittar risker som utvecklarna kan åtgärda.

Övning 2

Vilka tre utmaningar tror du att ett säkerhetsteam möter i vardagen?

Svarsinstruktion: Motivera dina svar. Beskriv också varför utmaningarna påverkar teamets sätt att planera arbete.

De två utmaningar jag kom att tänka på direkt är angreppsförsök utifrån och buggar i mjukvaran som missbrukas eller riskerar att missbrukas. En annan utmaning är push-back från antingen utvecklare, ledning eller kunder.

- **Utmaning: Angreppsförsök**

När vi hade våra skolservrar såg vi att angreppsförsök var väldigt vanligt. Bottar skannar efter öppna portar hela tiden. När det gäller större och kommersiella applikationer och tjänster får man anta att problemet är större och aktörer är mer aggressiva.

Påverkan på planeringen

Det kan vara svårt eller omöjligt att planera runt attacker, särskilt om det kommer en plötslig större attack. Om någonting akut inträffar måste säkerhetsteamet släppa det de jobbar med och åtgärda det akuta.

- **Utmaning: Buggar i mjukvaran**

Utvecklare har inte alltid säkerhetstänk. Det kan leda till att en bugg ligger i systemet och även om utvecklarna känner till den så prioriterar ingen att åtgärda den bara för att den inte påverkar funktionaliteten. Men till slut lyckas någon utomstående upptäcka den och utnyttjar den för destruktiva syften.

Påverkan på planeringen

Säkerhetsteamet är här beroende av utvecklarnas tid och planering. Även om säkerhetsteamet hittar en bugg måste de kunna få utvecklarna att åtgärda den, och det tar utvecklarnas tid och planering i anspråk.

- **Utmaning: Push-back från utomstående**

Många som inte kan någonting om säkerhet kan gärna tro att säkerhet är överskattat. De tror att ingenting kommer hända dem. De är inte Apple eller Facebook. Och säkerhet i mjukvara kan försämra funktioner eller användarvänlighet. Det gillar inte ledning och kunder. Därför tror jag att de ibland kan göra motstånd när det kommer till samarbetet med säkerhetsteamet.

Påverkan på planeringen

Här måste planeringen innefatta utbildningar och riskbedömningar, så att utomstående team och personer kan se och ta till sig problemen och riskerna med att vänta eller prioritera säkerheten för lågt. Och i slutändan är det trots allt ledningen som styr jobbet, så säkerhetsteamet kan behöva kompromissa.

Övning 3

Vilka kompetenser behöver finnas i ett säkerhetsteam?

Svarsinstruktion: Beskriv minst fem roller eller förmågor och förklara kort varför de behövs.

- **Nätverksspecialist**
Någon som förstår brandväggar, nätverksflöden, kryptering, segmentering. Någon som förstår nätverkstrafik och kan upptäcka avvikelser.
- **Applikationssäkerhetsexpert**
En programmeringskunnig som förstår hur koden är uppbyggd och kan förklara hur en risk kan byggas bort, eller varför säkerhetsteamet inte kan få precis som de vill när det gäller en annan risk. Jag tror även att en sådan har lättare att hitta buggar och utföra säkerhetstester på mjukvaran.
- **AI-specialist**
En person som kan sätta upp skydd med hjälp av AI, och för att motverka (yttre) AI. Vi såg i tidigare kurs hur effektivt en vältränad AI kan vara för att stoppa hot och hitta avvikelser.
- **GRC-specialist (Governance, Risk and Compliance)**
Alla team behöver någon som kan säga ifrån när någon råkar bryta mot lagen eller god standard. Det är även någon som kan gå igenom hur företaget efterlever regler och ramverk, och vad de behöver göra för att komma i fas med dessa.
- **Team Lead**
Gruppens "ledare". Kan delegera men även utföra uppgifterna själv. Kan kommunicera med ledning, kunder och andra team för att förstå vad som förväntas av teamet.
- **Utbildningsansvarig**
Någon som utbildar andra team, ledning och kunder i säkerhetstänket. Den som ber utvecklarna att sätta på brandväggen och lär kunderna att undvika vanliga misstag som att stoppa in upphittade USB-stickor i sina datorer.
- **Penetrationstestare**
Expert på att testa säkerheten i mjukvaror. Större team kan ha en eller flera i rollen, medan den i mindre team ofta bakas in i applikationssäkerhetsexpertens jobb.

Del 2 - Teamarbete

Övning 4

Formulera tre regler som du tycker bör finnas i er Team Charter.

Svarsinstruktion: Motivera varje regel. Koppla gärna till samarbete, ansvar, dokumentation eller kvalitet.

Dokumentera alla ändringar.

Om någon gör en ändring måste de andra i gruppen kunna se det. Det handlar om spårbarhet, men även att inte göra dubbelt arbete, och veta vad som gått fel om något händer för att lättare korrigera.

Delta i arbetet.

Var med på föreläsningar, workshops och gruppmöten. Gör det arbete du blir tilldelad. Om du får tid över, kolla om någon annan behöver hjälp.

Be om hjälp om du behöver.

Sitt inte och stirra om du kör fast. Fråga om någon i gruppen kan lösa problemet du fastnat på.

Övning 5

Beskriv hur ni vill kommunicera inom gruppen.

Svarsinstruktion: Beskriv när ni använder Teams, e-post, möten och dokumentation.

Kommunikation via de smidigaste kanalerna för stunden. Discord har bättre funktioner för möten än Slack, men protokoll och allt jobb ska dokumenteras och visas upp på Slack.

Möten sker i första hand på Discord. Gruppen har kommit överens om att prova Slack för möten.

Skolan vill att vi ska använda Slack i första hand, och Slack används i riktigt arbete så det vore bra att få in rutinerna för det även om plattformen inte är optimal för många saker.

Möten protokollförs och protokollen delas på Discord och Slack. Arbete dokumenteras och delas på Discord och Slack.

Övning 6

Hur bör en grupp agera om någon medlem inte hinner med sina uppgifter?

Svarsinstruktion: Beskriv ett arbetssätt som är tydligt, respektfullt och möjligt att följa upp.

Kommunikation. Om en gruppmedlem inte hinner med så är det bästa om personen tar upp det själv. Men annars får gruppen fråga om det finns någon anledning. Det kan vara något privat, eller för mycket annat i utbildningen, eller annat jobb, eller att personen helt enkelt missuppfattat sin uppgift. Vad det än är får gruppen lösa det tillsammans.

Del 3 - Product Backlog

Övning 7

Skapa fem backlog items kopplade till Threat Intelligence.

Svarsinstruktion: Varje backlog item ska ha titel och kort beskrivning.

Lista organisationens tillgångar (enligt CIS-kontroller)

- Ett av de första stegen bör vara att ta reda på vad organisationen har. Vi måste veta vad vi har att skydda.

Sammanställ en lista på godkända mjukvaror

- Skriv ner vilka program och mjukvaror som är tillåtna i organisationens system. Har vi koll på det kan vi se om något obehörigt dyker upp.

Kartlägg de största hoten

- Ta reda på var våra största hot kommer ifrån. Organisationer, individer, mjukvara, hårdvara? Vilka är mest sannolika att rikta in sig mot oss?

Skapa en rutin för att upptäcka och rapportera misstänkt phishing

- Phishing är ett av de lättaste sätten hotaktörer har att få tillgång till våra system.

Prenumerera på nyhetsbrev från MSB och CERT-SE

- För att vi ska bli snabbt uppdaterade om något händer i cybersäkerhetsvärlden.

Övning 8

Skapa fem backlog items kopplade till MITRE ATT&CK.

Svarsinstruktion: Tänk på vad ni behöver förstå, undersöka, dokumentera eller presentera.

Sätt upp en Threat Intelligence dashboard

- Vi har använt Wazuh i tidigare kurs. Något liknande i det här projektet vore väldigt användbart.

Skapa en rutin för att kontrollera loggar och leta efter misstänkt aktivitet

- Det går automatisera det mesta av loggövervakningen, men det är bra om en människa kollar till det lite manuellt ibland.

Identifiera vilka tekniker och taktiker som är relevanta för just oss

- Se över vilka specifika tekniker som är de största hoten för våra system för att kunna prioritera.

Dokumentera våra mitigerande åtgärder

- När vi skyddar oss/utför en skyddsåtgärd, skriv ner hur och varför. Annars kanske vi missar åtgärden, eller utför mitigering på flera olika sätt i onödan.

Studera de mest relevanta eller allvarliga teknikerna eller taktikerna som är relevanta för oss
- Vi behöver ta reda på hur vi ska hantera hoten de utgör.

Övning 9

Skapa fem backlog items kopplade till rapportering.

Svarsinstruktion: Fokusera på vad en mottagare behöver förstå av ert arbete.

Skapa en mall för incidentrapportering

- Ha ett enhetligt sätt att rapportera eventuella incidenter, hot och risker.

Planera nästa steg

- Sammanställ vad vi gjort och framförallt vad vi behöver göra nu. Prioritera.

Regelbunden rapport till ledningen

- Sammanfatta vad som hänt sen den senaste rapporten. Undvik att bli teknisk.

Dokumentera vad gruppen har gjort i veckan

- Dokumentation för att komma ihåg och senare kunna redovisa det vi gjort.

Sammanställ veckan i en liten presentation

- Kunna tala om för de andra grupperna vad och hur vi gjort. Gärna med snygga diagram och bilder.

Övning 10

Välj tre backlog items och skriv titel, beskrivning och förväntat resultat.

Svarsinstruktion: Formulera dem så att någon annan i gruppen skulle kunna förstå vad som ska göras.

Lista organisationens tillgångar:

Ta reda på vad organisationen äger som hör till IT.

Hårdvara: Datorer, nätverksutrustning, mobiler, surfplattor, skrivare. Allt som kan kopplas till nätverket.

Mjukvara: Operativsystem, installerade program som webbläsare, office-paket, antivirus. Specifik bransch-mjukvara och mjukvara utvecklad in-house. Kolla vilka molntjänster som är anslutna.

Data: Register, databaser, dokument relaterade till organisationens finanser.

Det är bättre att ha mer än vi behöver, för det är lättare att ta bort något från en lista än att ha en osäker enhet ansluten till nätverket.

Förväntat resultat: Ett färdigt dokument eller en databas med alla inventarier.

Sätt upp en Threat Intelligence dashboard:

Vi har använt Wazuh tidigare. Det ger en snabb och tydlig överblick över saker som händer, om det är korrekt konfigurerat. Vi kan även bygga vidare på det senare. Om det behövs, gå tillbaka till tidigare kurser och ta reda på hur man sätter upp Wazuh.

Förväntat resultat: Fungerande Wazuh med en dashboard som visar larm och annat viktigt vi kan ha användning för.

Regelbunden rapport till ledningen:

Det bästa vore att ha en mall som vi kan fylla i med det ledningen vill och behöver veta. Vad vi jobbat med, hur det har gått, om vi stött på problem, nästa steg. Det ska vara en strukturerad rapportmall som vi kan återanvända varje gång. Både för att göra det lättare för oss själva, och för ledningen. Och vi måste hålla det på en låg teknisk nivå så att ledningen förstår direkt vad vi menar.

Förväntat resultat: En färdig rapportmall med tydliga rubriker.

Del 4 - Prioritering

Övning 11

Prioritera era backlog items enligt Must Have, Should Have och Could Have.

Svarsinstruktion: Motivera minst tre av era prioriteringar.

Lista organisationens tillgångar (enligt CIS-kontroller)	Must Have
Motivering: Vi kan inte skydda något om vi inte vet att det existerar. Inventeringen måste ske tidigt.	
Sammanställ en lista på godkända mjukvaror	Should Have
Kartlägg de största hoten	Must Have
Det är viktigt att veta vad man skyddar sig mot. Då kan man även sålla bort hot som inte är relevanta.	
Skapa en rutin för att upptäcka och rapportera misstänkt phishing	Should Have
Prenumerera på nyhetsbrev från MSB och CERT-SE	Could Have
Motivering: Bra att ha, men det stoppar inte arbetet om man inte har det. Informationen kan man få från andra ställen.	
Sätt upp en Threat Intelligence dashboard	Should Have
Skapa en rutin för att kontrollera loggar och leta efter misstänkt aktivitet	Should Have
Identifiera vilka tekniker och taktiker som är relevanta för just oss	Must Have
Motivering: Samma som med inventeringen, det går inte skydda mot hot om man inte vet vilka de är.	
Dokumentera våra mitigerande åtgärder	Must Have
Motivering: Det är viktigt att kunna dokumentera vad man gör för att stoppa hot. Övriga i organisationen behöver veta vad som ändras och hur rutiner ser ut.	
Studera de mest relevanta eller allvarliga teknikerna eller taktikerna som är relevanta för oss	Should Have
Motivering: Lär oss extra mycket om just de allvarligaste hoten för att kunna skydda oss på bättre sätt.	
Skapa en mall för incidentrapportering	Should Have
Planera nästa steg	Should Have
Regelbunden rapport till ledningen	Should Have
Dokumentera vad gruppen har gjort i veckan	Should Have
Sammanställ veckan i en liten presentation	Could Have

Övning 12

Vilka tre aktiviteter anser du ger högst värde för projektet?

Svarsinstruktion: Förklara varför dessa aktiviteter bör prioriteras tidigt.

Lista organisationens tillgångar (enligt CIS-kontroller)
Som jag skrev ovan, vi vet inte vad vi ska skydda om vi inte vet vad som finns.

Identifiera vilka tekniker och taktiker som är relevanta för just oss
Som ovan, om vi inte vet vilka hot vi står inför kan vi inte skydda oss. Om vi vet det kan vi hindra hot från att bli verkliga angrepp. Bör göras efter inventeringen.

Dokumentera våra mitigerande åtgärder
Vi behöver från början vara tydliga och strukturerade med vilka åtgärder vi utför, ifall någonting förändras i system, nätverk, policy, eller rutiner för andra i organisationen. Det är bra om vi dokumenterar tydligt och enkelt så att de andra direkt förstår vad som gjorts, varför, och hur det påverkar organisationen.

Övning 13

Vilka aktiviteter skulle kunna vänta till senare?

Svarsinstruktion: Motivera varför dessa kan vänta utan att projektet tappar riktning.

Prenumerera på nyhetsbrev från MSB och CERT-SE
Det är jättebra att hålla sig uppdaterad, men den här aktiviteten påverkar nog det faktiska arbetet minst av alla jag skrivit ner. Informationen kan införskaffas från andra håll. Det positiva med prenumerationerna är att man kan få meddelanden direkt från i alla fall CERT-SE om något händer.

Sammanställ veckan i en liten presentation

Det uppskattas säkert att hålla andra i klassen uppdaterade, men just en presentation tillför väldigt lite värde till projektet, och kan ta viktig tid från oss att utföra mitigeringsåtgärder.

Sammanställ en lista på godkända mjukvaror

Om man utför den här för tidigt och för snabbt så kan andra team få problem. Den behöver förberedas och genomföras över tid så vi är säkra på att vi inte förbjuder någon kritisk mjukvara.

Del 5 - Sprint Goal

Övning 14

Formulera ett första Sprint Goal för gruppen.

Svarsinstruktion: Skriv max två meningar. Målet ska beskriva varför sprinten är värdefull.

Ett av våra första sprintmål var att alla skulle gå med i organisationen på GitHub. Detta för att alla skulle kunna arbeta på samma sätt och bidra lika lätt.

Övning 15

Beskriv hur ni ska veta att Sprint Goal är uppnått.

Svarsinstruktion: Skriv cirka 150 ord. Beskriv vilka tecken eller leverabler som visar att målet är uppnått.

Den Definition of Done som vi tagit fram är att uppgiften ska:

- Vara presentationsklar
- Innehålla relevanta delar
- Vara skriftligt dokumenterad
- Godkännas av en majoritet av gruppen

För att en uppgift ska anses vara färdig ska alla punkterna vara uppfyllda. Det ställer krav på oss att dokumentera och förstå uppgiften, och bara ha med det som är relevant utan att missa viktiga delar eller inkludera information som inte är relevant.

Presentationsklar:

Alla i gruppen ska kunna hålla en kort presentation om vad vi gjort, och det ska finnas dokumentation eller material att visa upp.

Relevanta delar:

För att visa att en backlog item är klar ska vi färdigställa den, och inte inkludera något som inte är nödvändigt. Samtidigt ska vi inte exkludera något viktigt eller något som hör till.

Skriftlig dokumentation

Processen ska vara dokumenterad på GitHub och/eller Slack. Det behöver inte vara en lång roman, men ska kort beskriva stegen vi utfört.

Godkännande:

När gruppmedlemmen som jobbat med ämnet anser det klart flyttas det till kolumnen för godkännande på GitHub. När en majoritet av alla gruppmedlemmar anser att det är färdigt flyttas den till Done. Det är viktigt att inte slentriangodkänna en punkt, utan vi måste tänka till lite före.

Övning 16

Vilka risker kan göra att sprintmålet inte uppnås?

Svarsinstruktion: Beskriv minst tre risker och föreslå hur gruppen kan minska dem.

- Missförstånd
Hela eller delar av gruppen kan missförstå en uppgift. Det är viktigt att vi, utbildare, och beställare/kund är tydliga med mål och krav.
- Brist på data
Vissa delar av ett sprintmål kan behöva data som vi inte har tillgång till, eller som vi inte kan inskaffa i tid. Eller så kan datan vara felaktig från början. Vi behöver verifiera data och säkerställa att vi samlar in bra data som vi använder i projektet.
- Velande kund
Kunden kan tänkas ändra sig mitt i sprinten, så att vi måste tänka om för att ta oss vidare. Fråga: Ska vi vara bestämda mot kunden, eller tala om för kunden vad vi anser att de behöver? Eller ska kunden få ändra sig hela tiden och vi anpassar oss efter det?
- Slarv från oss
Vi kanske är ofokuserade eller distraherade under en sprint, och missar att uppnå ett eller flera mål. Det är viktigt att vi prioriterar i alla fall utbildningen högst just nu. När vi väl är i branschen får vi lära oss snabbt vad som händer om medarbetare inte kan lita på oss.

Del 6 - Definition of Done

Övning 17

Lista minst fem kriterier som måste vara uppfyllda innan en uppgift räknas som klar.

Svarsinstruktion: Kriterierna ska gå att använda av hela gruppen.

Som ovan, men några punkter tillagda.

- Skriftligt dokumenterad
Processen är dokumenterad och gruppen har tillgång till dokumentationen.
- Versionshantering
Det vi gör ska kontinuerligt uppdateras och sparas på GitHub för automatisk versionshantering och backup.
- Innehåller endast relevanta delar
Inget extra och inget vi missat. Bara det som handlar om uppgiften.
- Följer struktur eller mall
Vi dokumenterar och strukturerar arbetet på samma sätt i varje uppgift så det blir lättare att följa.
- Presentationsklar
Vi ska kunna presentera uppgiften tydligt och enkelt för resten av klassen, utbildare eller kund. Det behöver inte vara en lång presentation.
- Kvalitetssäkring
Vi testar och säkertställer att uppgiften genomförts på rätt sätt och att resultatet blev vad vi ville.
- Granskning och godkännande
Gruppen måste granska och upptäcka eventuella felaktigheter, och när vi anser att det är okej kan vi godkänna uppgiften.

Övning 18

Ge exempel på en uppgift som ser klar ut men egentligen inte är det.

Svarsinstruktion: Motivera med hjälp av dokumentation, granskning, kvalitet eller spårbarhet.

Påhittat exempel: Mjukvarufunktion

En gruppmedlem bygger någon form av funktion i projektet. Medlemmen har skrivit ihop den lokalt på sin egen dator. Medlemmen har kört ett test och sett att den verkar fungera.

Varför uppgiften inte är klar:

- Saknar versionshantering och spårbarhet
Det går inte se hur processen gått till. Gruppen kan inte se vad som gjorts när och hur. Det finns ingen

tidigare version att gå tillbaka till om en nyare ändring skapat problem. Om medlemmen saknas så har inte gruppen tillgång till funktionen.

- Saknar dokumentation
Det finns inte instruktioner för hur funktionen används. Det är inte säkert funktionen följer uppsatta mallar och strukturer.
- Saknar riktig kvalitetssäkring
Ett test som visar att funktionen gör någonting visar inte att funktionen fungerar. Vi behöver testa funktionen på olika sätt, både när normala saker händer och när något oväntat inträffar, så vi ser vad som kan hända i verkligheten. Vi har inte heller granskat funktionen för att upptäcka fel.
- Inte godkänd av gruppen
Gruppen har inte haft möjlighet att granska funktionen och bedöma om den är klar. Det hör ihop lite med kvalitetssäkringen också.

Man kan fundera på om arbetet med funktionen skulle delas upp i flera delar för att kunna vara mer strukturerat. Då skulle man kunna testa och granska varje mindre del för sig själv, och sedan hela funktionen eller flera olika delar av den.

Del 7 - Förberedelse inför MITRE ATT&CK

Övning 19

Vilka frågor hoppas du få svar på under MITRE ATT&CK-workshopen?

Svarsinstruktion: Skriv minst fem frågor. Försök formulera frågor som hjälper er i projektarbetet.

1. Vad gör man om en kund eller beställare ändrar sig mitt i en sprint?
2. Hur bestämmer vi vilka tekniker som är relevanta för vårt projekt?
3. Hur bestämmer vi vilka tekniker som är relevanta för en specifik uppgift?
4. Hur går vi från en identifierad teknik till en mitigerande åtgärd?
5. Hur dokumenterar vi det vi gör på ett sätt som kunden förstår?
6. Hur hanterar vi hot och risker som använder tekniker som inte är dokumenterade i MITRE?
7. Hur uppdaterar vi vår hotmodell om ramverket ändras?

Övning 20

Vad tror du att MITRE ATT&CK kan användas till i ett säkerhetsteam?

Svarsinstruktion: Skriv 200-300 ord. Fokusera på analys, språk, prioritering och försvarsperspektiv.

Enligt MITREs [hemsida](#) kan ett säkerhetsteam använda MITRE ATT&CK för att upptäcka tekniker som en angripare använder, hjälpa till att strukturera och analysera hot, emulera ([efterlikna](#)) attacker, och hjälpa organisationen att fatta beslut om till exempel vilka verktyg de vill använda.

Deras matris beskriver många kända sätt (TTP:er, Taktiker/Tactics, Tekniker/Techniques och Procedurer/Procedures) för en hotaktör att samla data och information, att genomföra ett intrång, vad angriparen kan försöka göra när de tagit sig in, och vad slutmålet kan vara.

Matrisen innehåller även mitigerande åtgärder för varje listad taktik och teknik. Detta kan säkerhetsteamet använda sig av för att härda organisationens system och nätverk. Organisationens använder sig kanske inte av wifi ([MITRE T1669](#)) och behöver då inte mitigera det ([MITRE M1041](#)). Däremot är andra mitigeringar som rekommenderas för wifi-nätverk fortfarande relevanta för trådbundna nätverk.

MITRE skriver på hemsidan att matrisen inte är fulltäckande, men den tar upp många saker och mitigerar man majoriteten av de relevanta delarna bör organisationen vara väl skyddad enligt mig. Databasen uppdateras två gånger varje år. Då läggs nya tekniker till och information om tekniker som man lärt sig mer om redigeras.

Frivillig fördjupningsutmaning

Designa säkerhetsteamets första sprint.

Inkludera Sprint Goal, backlog, prioritering, Definition of Done, risker och leverabler. Max två sidor.